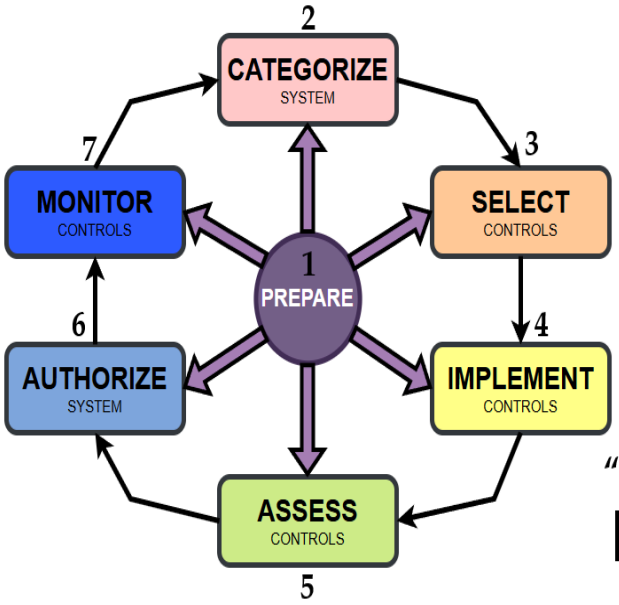


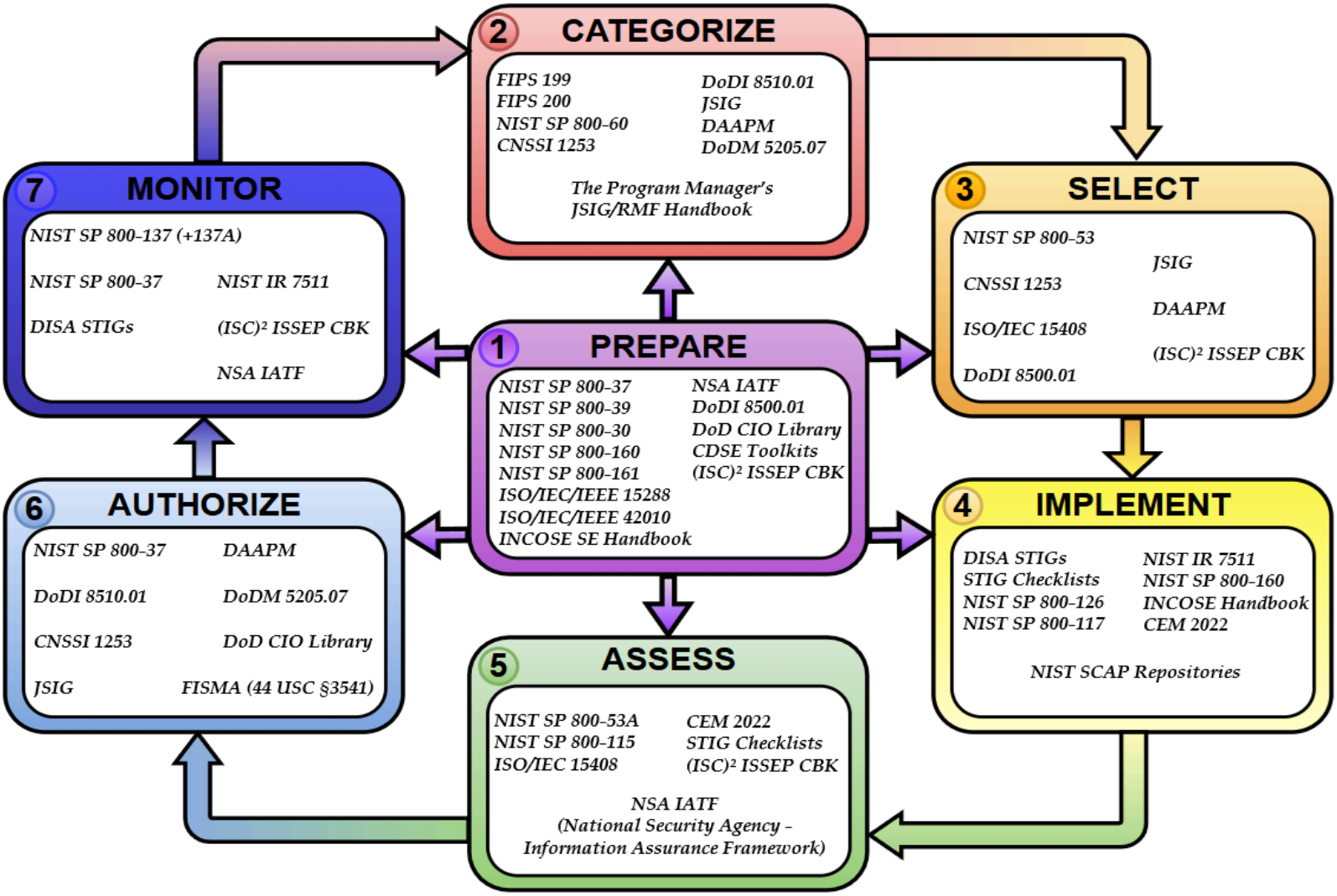
NIST SP 800-37 : The NIST Risk Management Framework (RMF)

7-step, lifecycle process that integrates security and risk management into federal systems by preparing, categorizing, selecting, implementing, assessing, authorizing, and continuously monitoring controls.

"People Can Secure Information And Approve Monitoring."

Prepare ⇨ Categorize ⇨ Select ⇨ Implement ⇨ Assess ⇨ Authorize ⇨ Monitor

RMF Step	Definition	Real Life ISSO Use Case
Prepare	Establish organizational context, assign roles, identify stakeholders, and ready resources/policies for RMF execution.	➢ Drafting **System Security Plans (SSPs)** with program context. ➢ Using **Qmulos Q-Audit** to baseline audit log requirements and map AU controls.
Categorize	Assign impact levels (Confidentiality, Integrity, Availability) to the system per FIPS 199/200 and CNSSI 1253.	➢ Documenting categorization/classification in **eMASS/ATO package**. ➢ Mapping the categorization/classification to **AU/SC/AC families** for required STIGs and overlays.
Select	Choose baseline security controls (NIST 800-53 + JSIG overlays), tailoring as needed for mission/system.	➢ Applying **JSIG SAP overlay** controls to the RMF baseline. ➢ Building your **Control Matrix (AU, AC, CM, SC, SI)** and tying each control to an enforcement tool (Splunk, Nessus, STIG Viewer)
Implement	Put selected security controls in place and configure them for the system.	➢ Hardening systems using **STIG Viewer + SCAP scans** ➢ Setting **auditd rules and Splunk forwarders** for proper logging.
Assess	Evaluate whether controls are implemented correctly and function as intended.	➢ Running **Nessus scans** and reviewing compliance reports. ➢ Reviewing **Splunk dashboards** for complete & accurate events
Authorize	A senior official (AO) makes a risk-based decision to approve (or deny) system operation.	➢ Assembling **POA&M findings** from Nessus + STIG Viewer. ➢ Briefing AO/ISSM on residual risk with **compliance dashboards from Qmulos**.
Monitor	Continuously track the system's security posture, remediate issues, and adapt to change.	➢ Reviewing **Splunk SIEM alerts** regularly for audit anomalies. ➢ Running **Monthly Nessus scans** and **Quarterly SCAP scans** to maintain vulnerability awareness.



			NIST Publications	Alternate Publications
1	Prepare	*Set the stage: define roles, resources, risk strategy, and supply chain context.*	SP 800-37 SP 800-39 SP 800-30 SP 800-160 SP 800-161	ISO/IEC/IEEE 15288 ISO/IEC/IEEE 42010 INCOSE SE Handbook NSA IATF DoDI 8500.01 DoD CIO Library CDSE ISSO Toolkits (ISC)² ISSEP CBK
2	Categorize	**(CLASSIFICATION OF ASSETS)** *Identify system info types and assign impact levels (low/mod/high).*	SP 800-60 FIPS 199 FIPS 200	CNSSI 1253 DoDI 8510.01 JSIG DAAPM DoDM 5205.07 PM's JSIG/RMF Handbook
3	Select	*Choose and tailor security controls based on impact, overlays, and requirements.*	NIST SP 800-53	CNSSI 1253 ISO/IEC 15408 DoDI 8500.01 JSIG DAAPM (ISC)² ISSEP CBK
4	Implement	*Put the chosen controls in place — technical, procedural, and physical.*	SP 800-126 SP 800-117 NIST IR 7511 SP 800-160 NIST SCAP Repositories	DISA STIGs STIG Checklists CEM 2022 (Common Criteria 'How-To') INCOSE Systems Security Engineering
5	Assess	*Test and evaluate controls to confirm they're effective.*	SP 800-53A SP 800-115	ISO/IEC 15408 CEM 2022 NSA IATF STIG Checklists SCAP Baselines (ISC)² ISSEP CBK
6	Authorize	*Decision point: accept or deny system risk (ATO).*	SP 800-37	CNSSI 1253 DoDM 5205.07 JSIG DAAPM DoDM 5205.07 DoD CIO Library FISMA (44 USC §3541)
7	Monitor	*Continuously track, assess, and respond to changes in risk and control effectiveness.*	SP 800-137 SP 800-137A SP 800-37 NIST IR 7511	DISA STIGs (ISC)² ISSEP CBK NSA IATF

NIST SP 800-53 Control Families Real Life Applicibility

ID	Control Family Name	Category	Main Responsible Entities
AC	Access Control	Technical	ISSO
AT	Awareness and Training	Operational	Users (with ISSO Oversight)
AU	Auditing and Accountability	Technical	ISSO
CA	Security Assessment and Authorization	Management	ISSM
CM	Configuration Management	Technical	ISSO, System Administrator
CP	Contingency Planning	Operational	All Roles (Management Enablement)
IA	Identification and Authentication	Technical	ISSO
IR	Incident Response	Operational	All Roles (Management Enablement)
MA	Maintenance	Technical	ISSO, System Administrator
MP	Media Protection	Operational	CPSO, DTA, Media Custodian
PE	Physical and Environmental Protection	Operational	FSO, CPSO
PL	Planning	Management	PM
PM	Program Management	Management	PM
PS	Personnel Security	Operational	CPSO, PSO
PT	PII Processing and Transparency	Operational	CPSO, PSO
RA	Risk Assessment	Management	ISSM
SA	System and Services Acquisition	Management	PM
SC	System and Communications Protection	Technical	ISSO, Network Administrator
SI	System and Information Integrity	Technical	ISSO, System Administrator
SR	Supply Chain Risk Management	Management	ISSO, ISSM

NIST SP 800-53 Control Families Mapped to NIST SP 800-37 RMF

1	Prepare	Controls acting as foundations for risk management and org-level readiness.
2	Categorize	Controls that support defining impact and security requirements.
3	Select	Controls used to guide tailoring and baseline selection.
4	Implement	Controls tied directly to putting security/privacy measures in place.
5	Assess	Controls supporting verification of control effectiveness.
6	Authorize	Controls that ensure decision-making accountability.
7	Monitor	Controls tied to ongoing visibility and response.

ID	Control Family Name	RMF Step	NIST SP 800-37 RMF Phase Alignment
AC	Access Control	4	**IMPLEMENT** Controls
AT	Awareness and Training	1	**PREPARE** The RMF
AU	Auditing and Accountability	7	**MONITOR** Controls
CA	Security Assessment and Authorization	5	**ASSESS** Controls
CM	Configuration Management	4	**IMPLEMENT** Controls
CP	Contingency Planning	7	**MONITOR** Controls
IA	Identification and Authentication	4	**IMPLEMENT** Controls
IR	Incident Response	7	**MONITOR** Controls
MA	Maintenance	4	**IMPLEMENT** Controls
MP	Media Protection	4	**IMPLEMENT** Controls
PE	Physical and Environmental Protection	4	**IMPLEMENT** Controls
PL	Planning	1	**PREPARE** The RMF
PM	Program Management	6	**AUTHORIZE** System
PS	Personnel Security	1	**PREPARE** The RMF
PT	PII Processing and Transparency	3	**SELECT** Controls
RA	Risk Assessment	2	**CATEGORIZE** System
SA	System and Services Acquisition	3	**SELECT** Controls
SC	System and Communications Protection	4	**IMPLEMENT** Controls
SI	System and Information Integrity	7	**MONITOR** Controls
SR	Supply Chain Risk Management	3	**SELECT** Controls

PREPARE The RMF

AC-1	CM-9	PL-4	PM-7	PM-17	PM-26	PS-7
AT-1	CP-1	PL-7	PM-8	PM-18	PM-27	PS-8
AT-2	IA-1	PL-8	PM-9	PM-19	PS-1	PT-1
AT-3	IR-1	PL-9	PM-11	PM-20	PS-2	RA-1
AT-4	MA-1	PM-1	PM-12	PM-21	PS-3	SA-1
AT-6	MP-1	PM-2	PM-13	PM-22	PS-9	SC-1
AU-1	PE-1	PM-3	PM-14	PM-23	PS-4	SI-1
CA-1	PL-1	PM-5	PM-15	PM-24	PS-5	SR-1
CM-1	PL-2	PM-6	PM-16	PM-25	PS-6	

Hallmark SP 800-53 Control Families

AT - Awareness & Training	PL - Planning	PS - Personnel Security

The PREPARE step sets the foundation by defining policies, roles, training, and baseline expectations to ready the organization for system categorization and risk management.

AC – Prepare access policies to guide initial privilege assignment.

AT – Establish training programs to ready the workforce.

AU – Define audit requirements for future monitoring.

CA – Set the foundation for assessment and authorization planning.

CM – Develop baseline configuration control policies.

CP – Draft contingency strategies before system use.

IA – Define identification and authentication requirements early.

IR – Prepare incident response policies and responsibilities.

MA – Establish secure maintenance expectations in advance.

MP – Prepare handling rules for sensitive media.

PE – Define physical security standards for system areas.

PL – Develop overarching security and risk plans.

PM – Align security with governance and enterprise strategy.

PS – Prepare personnel vetting and access requirements.

PT – Integrate privacy requirements into preparation.

RA – Conduct initial risk assessments to inform planning.

SA – Build acquisition policies that embed security.

SC – Prepare baseline protections for system communications.

SI – Define integrity safeguards for system readiness.

SR – Prepare supply chain risk management expectations.

CATEGORIZE System				
RA-2	**RA-3**	**RA-7**	**RA-8**	**RA-9**

Hallmark SP 800-53 Control Families

RA - Risk Assessment

The CATEGORIZE step defines system criticality and sensitivity by assessing risks, impacts, and data types, establishing the security category that drives all subsequent control selection.

RA - Categorize systems by evaluating risk, impact, and information sensitivity to establish the security baseline.

The **major relationship** between a **Risk Assessment** and the **NIST RMF Categorize step** is that the Categorize step establishes the ***risk context*** for the system by determining its **security impact level**, and that determination is directly informed by **risk assessment activities**.

RA-2 – Define the system's security categorization.

RA-3 – Apply categorization to information types and processing.

RA-7 – Identify and record risk assumptions and constraints.

RA-8 – Document criticality for mission/business alignment.

RA-9 – Capture privacy and data sensitivity impacts.

SELECT Controls							
AC-5	CM-11	PT-4	SA-3	SA-11	SA-17	SA-23	SR-7
AC-6	PL-10	PT-5	SA-4	SA-12	SA-18	SR-2	SR-8
AC-14	PL-11	PT-6	SA-5	SA-13	SA-19	SR-3	SR-9
AC-16	PM-30	PT-7	SA-8	SA-14	SA-20	SR-5	SR-10
CM-7	PT-2	PT-8	SA-9	SA-15	SA-21	SR-4	SR-11
CM-10	PT-3	SA-2	SA-10	SA-16	SA-22	SR-6	SR-12

Hallmark SP 800-53 Control Families

PT - PII Processing & Transparency
SA - System & Services Acquisition
SR - Supply Chain Risk Management (SCRM)

The SELECT step tailors and documents security and privacy controls based on system categorization, mission needs, and organizational risk tolerance, ensuring safeguards are appropriate, feasible, and aligned with supply chain and acquisition requirements.

AC – Select control mechanisms to enforce least privilege, separation of duties, and secure access methods aligned with system criticality.

CM – Select restrictions on functions, services, and unauthorized software to minimize the attack surface.

PL – Define security and privacy plans that document chosen controls and how they support risk objectives.

PM – Align selected controls with enterprise-level governance to ensure consistency across systems.

PT – Select privacy controls addressing consent, data minimization, retention, and accountability requirements**.**

SA – Select security requirements for system development, acquisition, and supply chain, embedding protections through contracts, testing, and lifecycle management.

SR – Select supplier and acquisition safeguards that reduce risk from external dependencies and ensure component authenticity, resilience, and secure sourcing.

IMPLEMENT Controls

AC-2	AC-22	AU-10	CM-14	IA-5	MA-5	PE-5	PE-19	SC-7	SC-20	SC-33	SC-46
AC-3	AC-23	AU-14	CP-2	IA-6	MA-6	PE-6	PE-20	SC-8	SC-21	SC-34	SC-47
AC-4	AC-24	AU-16	CP-6	IA-7	MA-7	PE-8	PE-21	SC-9	SC-22	SC-35	SC-48
AC-7	AC-25	CA-3	CP-7	IA-8	MP-2	PE-9	PE-22	SC-10	SC-23	SC-36	SC-49
AC-9	AU-2	CA-9	CP-8	IA-9	MP-3	PE-10	PE-23	SC-11	SC-24	SC-37	SC-50
AC-10	AU-3	CM-2	CP-9	IA-10	MP-4	PE-11	RA-5	SC-12	SC-25	SC-38	SC-51
AC-11	AU-12	CM-3	CP-10	IA-11	MP-5	PE-12	RA-6	SC-13	SC-26	SC-39	
AC-12	AU-4	CM-4	CP-11	IA-12	MP-7	PE-13	RA-10	SC-14	SC-27	SC-40	
AC-17	AU-5	CM-5	CP-12	IR-8	MP-6	PE-14	SC-2	SC-15	SC-28	SC-41	
AC-18	AU-7	CM-6	CP-13	IR-9	MP-8	PE-15	SC-3	SC-16	SC-29	SC-42	
AC-19	AU-11	CM-8	IA-2	MA-2	PE-2	PE-16	SC-4	SC-17	SC-30	SC-43	
AC-20	AU-8	CM-12	IA-3	MA-3	PE-3	PE-17	SC-5	SC-18	SC-31	SC-44	
AC-21	AU-9	CM-13	IA-4	MA-4	PE-4	PE-18	SC-6	SC-19	SC-32	SC-45	

Hallmark SP 800-53 Control Families

AC - Access Control CM - Configuration Management IA - Identification & Authentication
MA - Maintenance MP - Media Protection PE - Physical & Env. Protection SC - System and Comms Protection

The IMPLEMENT step applies and integrates the selected security and privacy controls into the system architecture, operations, and environment, ensuring protections are functioning as intended and aligned with mission needs.

AC – Implement technical and procedural mechanisms to enforce least privilege, user access restrictions, and secure remote connectivity.

AU – Deploy and configure logging, monitoring, and audit mechanisms to ensure events are recorded, protected, and actionable.

CA – Apply connection and information exchange controls to ensure secure interoperability between systems.

CM – Implement secure baselines, change control, and system inventories to manage configuration throughout the lifecycle.

CP – Put continuity, backup, and recovery mechanisms into operation, ensuring resiliency during disruptions.

IA – Implement identity proofing, credential management, and multifactor authentication for users and devices.

IR – Establish incident reporting and coordination mechanisms within the operational environment.

MA – Apply secure maintenance practices, including monitoring, sanitization, and authorization for activities.

MP – Implement controls for labeling, encrypting, transporting, and sanitizing system media.

PE – Deploy physical safeguards such as facility access controls, monitoring, and environmental protections.

RA – Implement vulnerability scanning and penetration testing to inform operational risk posture.

SC – Apply encryption, boundary defenses, session controls, and communication safeguards to secure system functions and data flows.

ASSESS Controls					
CA-2	**CA-8**	**CP-3**	**CP-4**	**IR-2**	**IR-3**

Hallmark SP 800-53 Control Families

CA - Security Assessment & Authorization

The ASSESS step evaluates the effectiveness of implemented controls through testing, validation, and exercises, ensuring safeguards perform as intended and risks are accurately understood.

CA – Conduct security control assessments and penetration/exchange testing to validate effectiveness.

CP – Test recovery and continuity plans through exercises to confirm operational readiness.

IR – Assess and test incident response processes through simulations and coordination drills.

AUTHORIZE System				
CA-5	**CA-6**	**PM-4**	**PM-10**	**PM-28**

Hallmark SP 800-53 Control Families

PM - Program Management

The AUTHORIZE step formalizes risk decisions by reviewing assessment results, weighing residual risk, and granting approval for system operation under defined conditions.

CA – Document risk posture and residual risk, ensuring only systems meeting acceptable thresholds are authorized.

PM – Provide organizational oversight, accountability, and enterprise-level acceptance of risk to support the authorization decision.

MONITOR Controls

AU-6 AU-13 CA-7 IR-4	IR-5 IR-6 IR-7 PM-31	PM-32 SI-2 SI-3 SI-4	SI-5 SI-6 SI-7 SI-8	SI-9 SI-10 SI-11 SI-12	SI-13 SI-14 SI-15 SI-16	SI-17 SI-18 SI-19 SI-20	SI-21 SI-22 SI-23

Hallmark SP 800-53 Control Families

AU - Auditing & Accountability
CP - Contingency Planning
IR - Incident Response
SI - System & Information Integrity

The MONITOR step maintains ongoing awareness of security posture by continuously tracking controls, detecting events, and updating risk decisions throughout the system lifecycle.

AU – Continuously review and analyze audit logs to detect anomalies and support investigations.

CA – Perform ongoing assessments and reporting to track control effectiveness.

IR – Monitor, detect, and manage incidents in real time, refining response activities.

PM – Provide enterprise oversight for continuous monitoring and reporting requirements.

SI – Detect, analyze, and correct flaws, malicious code, and integrity issues through ongoing monitoring and protective technologies.